

ICT2217

Network Security

Lab 3.2 Notes:

AAA Part I – Authentication



Lab Exercise Part 1

1

Configure device access **authentication** using **locally stored** passwords and/or usernames.

Cisco supports **simple password security without username** for console and telnet **login**. But, everyone will use the same password!

```
switch(config)# line con 0  
switch(config-line)# password hope  
switch(config-line)# login
```



Console Password

```
switch(config)# enable password faith
```

User Mode

Enable Password

Enable Mode

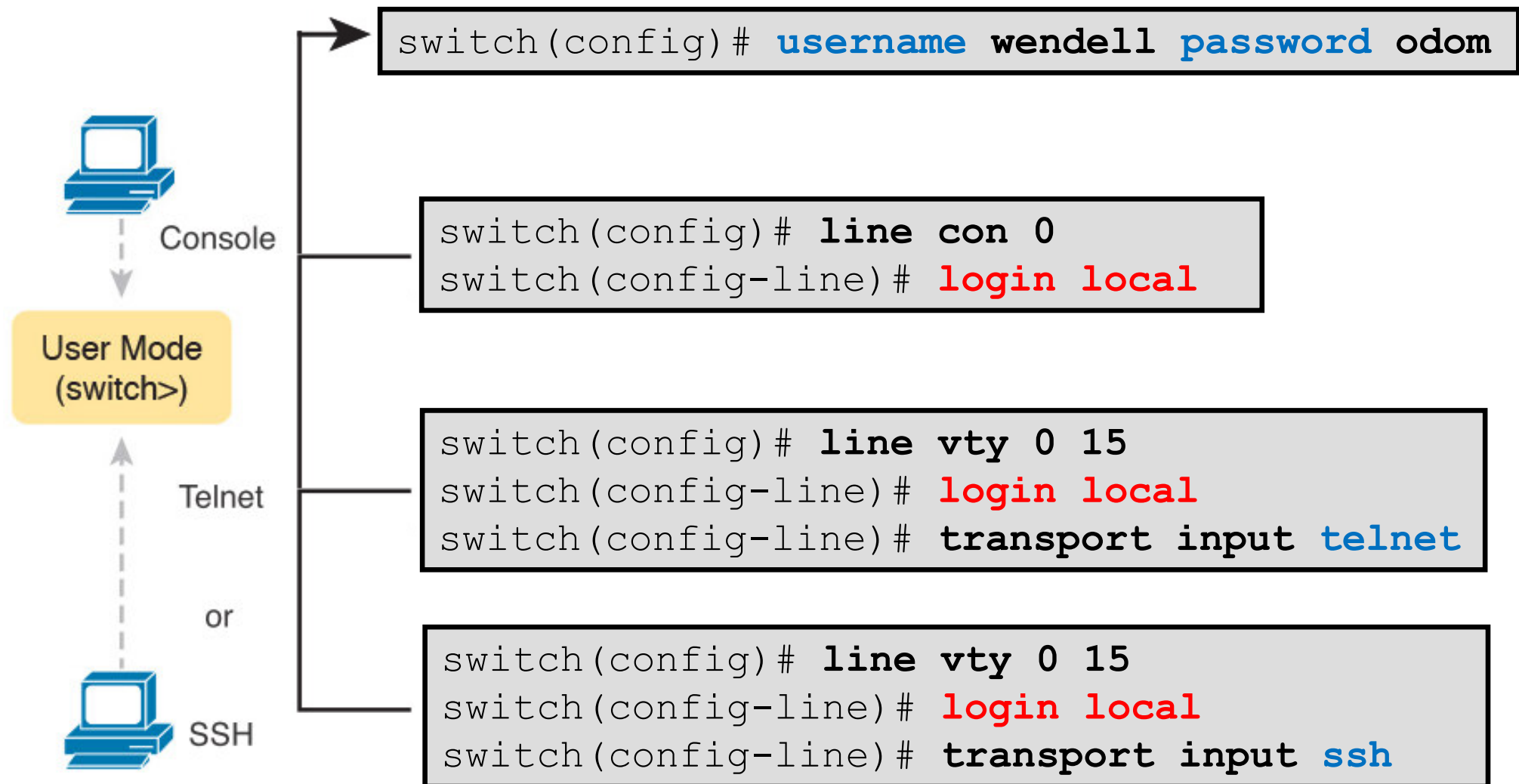


Telnet Password

```
switch(config)# line vty 0 15  
switch(config-line)# password love  
switch(config-line)# login
```

- **password** *password-string* command defines the password
- **login** command enables simple password security
- **enable password** *password-string* command for enable mode password

A better **authentication** method will be to configure for each user a locally stored (**login local**) unique **username** and **password** which is a requirement for SSH.



By default, Cisco stores passwords in the configuration file in clear, which can be encrypted using the **service password-encryption** command but the protection is very weak.

```
R1(config)# service password-encryption
R1(config)# exit
R1# show running-config
```

<output omitted>

```
line con 0
  exec-timeout 3 30
  password 7 094F471A1A0A
  login
line aux 0
  exec-timeout 3 30
  password 7 094F471A1A0A
  login
line vty 0 4
  password 7 094F471A1A0A
  login
```

Cisco Cracker

094F471A1A0A

Crack it

Password = Cisco

To provide better protection, Cisco has implemented **cryptographic algorithms** like **md5**, **sha256** and **scrypt** which you will learn in the Applied Crypto module.

By replacing '**password**' command with '**secret**', **MD5 hash** will be used to protect user passwords in the configuration file by default.

```
Router(config) #
```

```
username name secret unencrypted-password
```

```
Router(config) #
```

```
enable secret unencrypted-password
```

For even better protection, **sha256** and **scrypt** are recommended:

```
Router(config) #
```

```
username name algorithm-type {md5 | scrypt | sha256 } secret unencrypted-password
```

```
Router(config) #
```

```
enable algorithm-type {md5 | scrypt | sha256 } secret unencrypted-password
```

Cisco has also provided additional features to **slow down brute-force attack** on login as follows:

```
R1(config)#
```

```
login delay seconds
```

```
login block-for seconds attempts tries within seconds
```

To prevent DoS attack denying authorized administrators from login during this **block-for period** called **quiet-mode**, you may configure ACL to allow login before block-for timer expires as follows:

```
R1(config)#
```

```
login quiet-mode access-class {acl-name|acl-number}
```

```
R1(config)# ip access-list standard PERMIT-ADMIN
R1(config-std-nacl)# remark Permit only Administrative hosts
R1(config-std-nacl)# permit 192.168.10.10
R1(config-std-nacl)# permit 192.168.11.10
R1(config-std-nacl)# exit
R1(config)# login quiet-mode access-class PERMIT-ADMIN
```

For **accounting** purpose (to be discussed later), it is also useful to **log login attempts**.

```
R1(config)#
```

```
login on-success log [every login]
```

```
R1(config)#
```

```
login on-failure log [every login]
```

```
Router#  
*Nov 1 08:53:54.571: %SEC_LOGIN-4-LOGIN_FAILED: Login failed [user: wendell]  
[Source: 192.168.1.10] [localport: 23] [Reason: Login Authentication Failed -  
BadPassword] at 08:53:54 UTC Thu Nov 1 2018  
Router#
```

```
Router#  
Router#show login failures  
Total failed logins: 2  
Detailed information about last 50 failures
```

Username	lPort	Count	TimeStamp	SourceIPAddr
wendell	23	2	08:53:54 UTC Thu Nov 1 2018	192.168.1.10

Lab Exercise Part 2 and 3

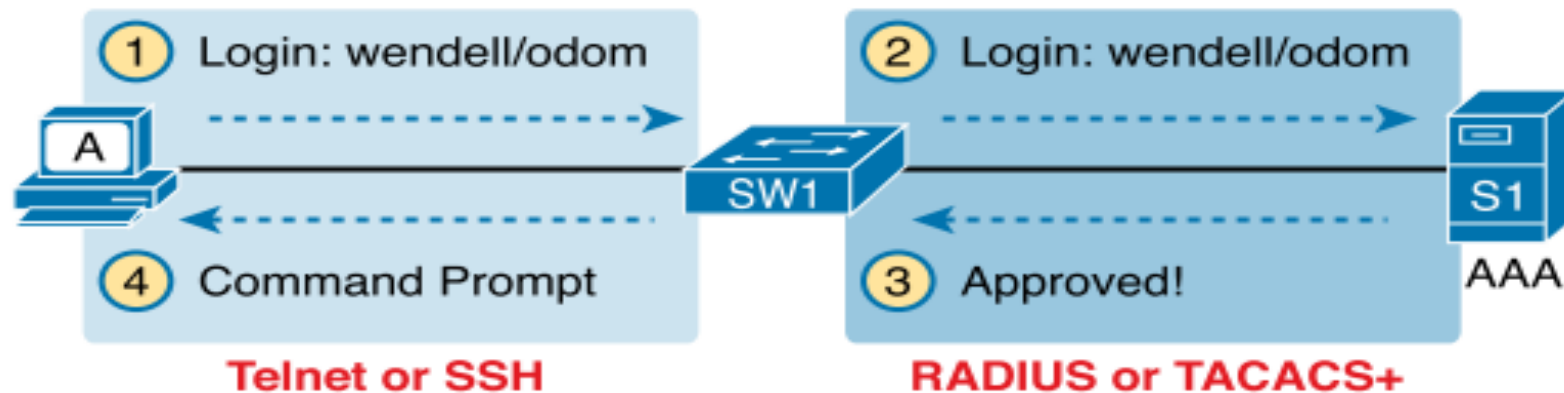
2 – 3

Configure device access **authentication** using **centralized AAA servers to store** usernames and passwords.

A better and more practical way is to store passwords in an **external centralised AAA server (server-based AAA)** for authentication, especially when managing many devices.

Benefits of **server-based AAA**:

- **Scalability** and **manageability**: the configuration of usernames and passwords is centralized and not repeated in every device
- **Fault tolerance**: multiple AAA servers can be configured for backup purpose



Communication between **network devices** and **AAA servers** typically uses **RADIUS** or **TACACS+** (Terminal Access Controller Access-Control System, pronounced as 'tack-axe' from Cisco textbooks) protocols.

To enable authentication using centralised AAA server, configure using **AAA** commands, e.g. with TACACS+ as follows:

```
SW1 (config) # aaa new-model
```

1. Enable AAA

```
SW1 (config) # tacacs server TACACSVR
```

2. Specify AAA server

```
SW1 (config-server-tacacs) # address ipv4 192.168.1.11
```

```
SW1 (config-server-tacacs) # key TACACS-pa55w0rd
```

```
SW1 (config-server-tacacs) # exit
```

! **Default method list** is automatically applied to console and
! vty(Telnet and SSH) if no custom method list is configured

```
SW1 (config) # aaa authentication login default group tacacs+
```

3. Configure authentication method list (either default above or custom below)

! **Or**, configure **custom method list** for authentication

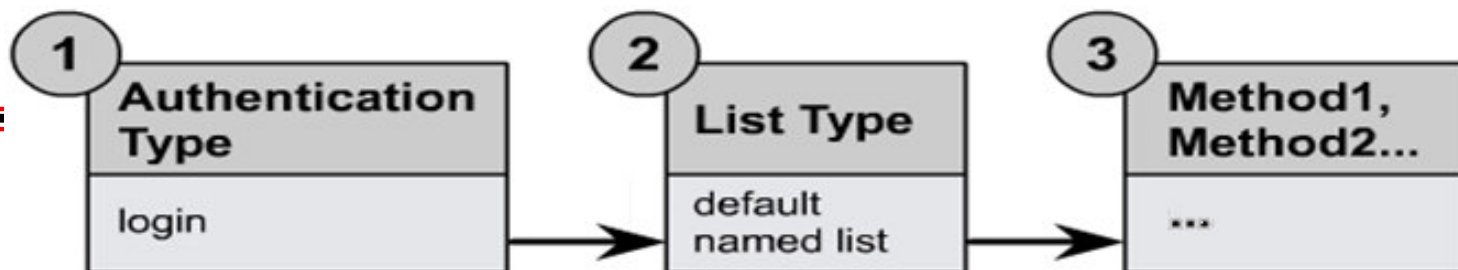
```
SW1 (config) # aaa authentication login MY-LIST group tacacs+
```

```
SW1 (config) # line vty 0 15
```

```
SW1 (config-line) # login authentication MY-LIST
```

4. Unlike default method list, custom method list must be applied at interface to be effective

Here is an explanation of the common **methods** for use with **aaa authentication** command to configure the **method list**:



```
Router(config)#aaa authentication type {default | list-name}  
method1 [...]method4]
```

Methods	Description
local	Use local username for authentication.
local-case	Use case-sensitive local username for authentication.
enable	Use enable password for authentication.
none	No authentication.
group radius	Use the configured RADIUS servers for authentication.
group tacacs+	Use the configured TACACS+ server for authentication.
group group-name	Use the configured RADIUS or TACACS+ servers for authentication as defined by the command aaa group server radius group-name or aaa group server tacacs+ group-name .

Next, setup AAA server, e.g. **TACACS+** server using the free [tacacs.net](https://www.tacacs.net) which you'll try out in the lab exercise.

After downloading and installing TACACS+, go to config folder and modify the following configuration files:

In [tacplus.xml](#), modify IP address to match your TACACS+ server:

```
<Server xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"  
  <Port>49</Port>  
  <LocalIP>127.0.0.1</LocalIP>
```

In [clients.xml](#), specify IP addresses of network devices (TACACS+ clients), and the shared password with TACACS+ server:

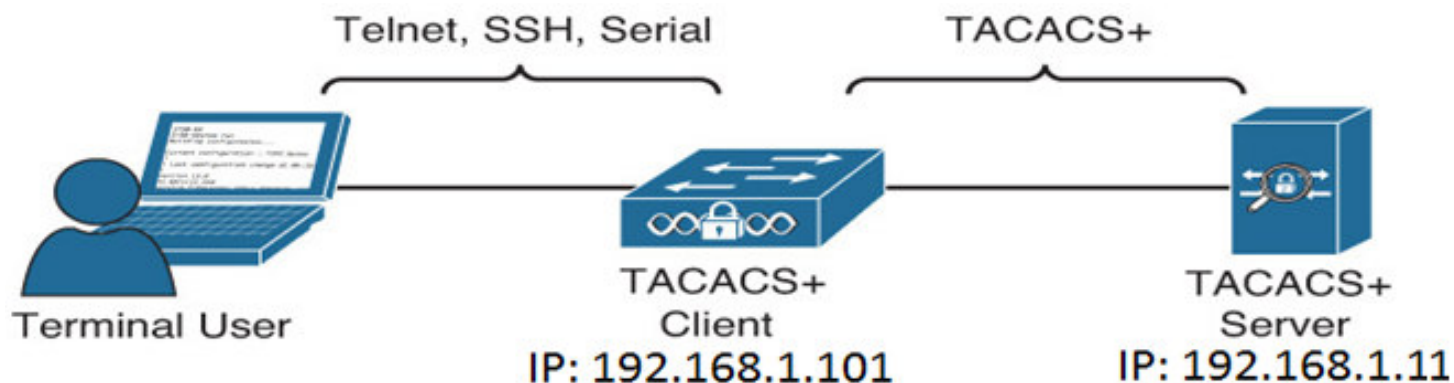
```
<ClientGroup Name="INTERNAL">  
  <Secret ClearText="TACACS-pa55w0rd" DES=""> </Secret>  
  <Clients>  
    <Client>10.0.0.0/8</Client>  
    <Client>172.16.0.0/12</Client>  
    <Client>192.168.0.0/16</Client>  
  </Clients>  
</ClientGroup>
```

Read the documentation at <https://www.tacacs.net/documentation/>

In addition, configure **username**s and **password**s centrally in AAA server, e.g. in tacacs.net as follows:

Configuring username and password in **authentication.xml**

```
<UserGroup>
  <Name>Network Engineering</Name>
  <AuthenticationType>File</AuthenticationType>
  <Users>
    <User>
      <Name>wendell</Name>
      <LoginPassword ClearText="odom" DES=""> </LoginPassword>
      <EnablePassword ClearText="" DES=""></EnablePassword>
      <CHAPPassword ClearText="" DES=""> </CHAPPassword>
      <OutboundPassword ClearText="" DES=""> </OutboundPassword>
    </User>
  </Users>
</UserGroup>
```



For redundancy, **AAA** can be configured with multiple methods, e.g. **TACACS+** server, **RADIUS** server, and **local database** (to avoid being locked out if AAA servers are down).

```
R1(config)# aaa new-model
R1(config)# tacacs server TACACSERVER
R1(config-server-tacacs)# address ipv4 192.168.1.11
R1(config-server-tacacs)# key TACACS-pa55w0rd
R1(config)#
R1(config)# radius server RADIUSERVER
R1(config-radius-server)# address ipv4 192.168.1.12 auth-port
1812 acct-port 1813
R1(config-radius-server)# key RADIUS-pa55w0rd
R1(config)#
R1(config)# username ADMIN secret Str0ngPa55w0rd
R1(config)#
R1(config)# aaa authentication login default group tacacs+
group radius local
```

An example of **RADIUS** server is the free open source and most widely deployed **freeRADIUS** server which you will also try out in the lab exercise.

It's easier to install and run freeRADIUS in Kali Linux, follow the guide at [https://wiki.freeradius.org/guide/Getting Started](https://wiki.freeradius.org/guide/Getting%20Started)

In **clients.conf** specify IP addresses of supported network devices and shared password:

```
client networkdevices {  
    ipaddr      = 192.168.1.0/24  
    secret      = RADIUS-pa55w0rd  
}
```

In file "**users**", configure username and password:

```
wendell Cleartext-Password := "odom"
```

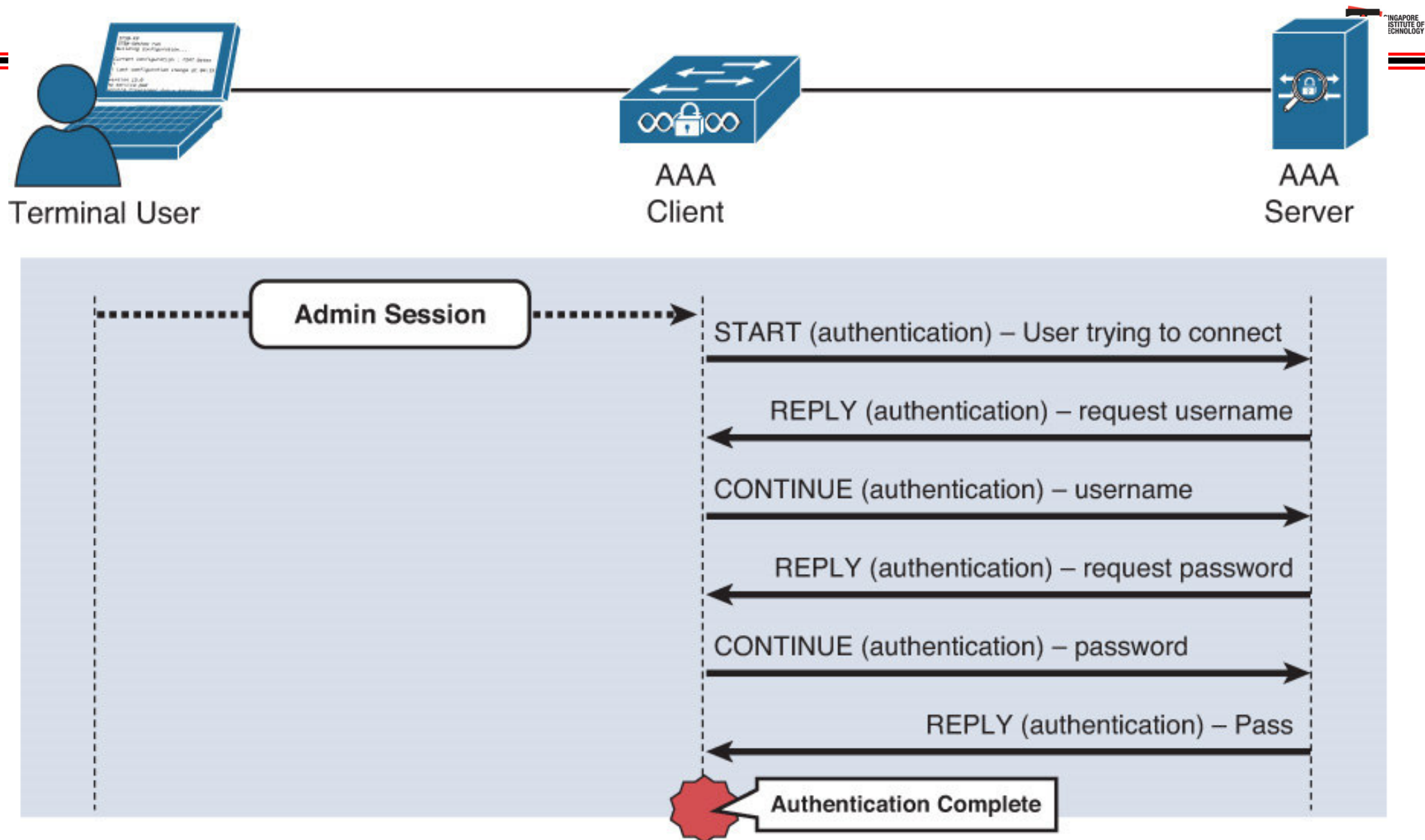
PC with terminal
emulation software



In summary, here is a table comparing **TACACS+** vs **RADIUS** for implementing **AAA**.

	TACACS+	RADIUS
Functionality	Separates authentication, authorization and accounting, allowing modularity of the security server implementation	Combines authentication and authorization but separates accounting, allowing less flexibility in implementation than TACACS+.
Standard	Mostly Cisco supported	Open/RFC standard
Transport Protocol	TCP port 49	UDP port 1812 and 1813
Security	Entire packet encrypted	Password encrypted
Authorization	Provides authorization of commands on a per-user or per-group basis.	Has no option to authorize router commands on a per-user or per-group basis
Primary Use	Device administration	Network access

Specifically, **authentication** in **TACACS+** is done separately from authorization and accounting as shown:



In contrast, **authentication** in **RADIUS** is done together with authorization in the same Access-Accept reply message as shown:

